



Guide Essentiel de la Sécurité Informatique

Principes fondamentaux, authentification, cryptographie, sécurité réseau, menaces courantes et bonnes pratiques

Rapport pédagogique — 8 pages

1. Introduction à la sécurité informatique

La sécurité informatique regroupe l'ensemble des pratiques visant à protéger les systèmes, les réseaux et les données contre les accès non autorisés, les altérations ou les interruptions de service. Elle repose sur un équilibre entre protection technique, processus organisationnels et sensibilisation des utilisateurs.

La triade CIA

Principe	Signification
Confidentialité	Seules les personnes autorisées peuvent accéder à l'information.
Intégrité	Les données ne sont pas altérées de façon non autorisée ou accidentelle.
Disponibilité	Les systèmes et données restent accessibles quand on en a besoin.

Concepts fondamentaux

- **Vulnérabilité** : faiblesse dans un système pouvant être exploitée.
- **Menace** : événement ou acteur susceptible d'exploiter une vulnérabilité.
- **Risque** : probabilité qu'une menace se concrétise, combinée à son impact.
- **Surface d'attaque** : ensemble des points par lesquels un système peut être atteint.

Une responsabilité partagée

La sécurité n'est pas uniquement l'affaire des équipes techniques : chaque utilisateur contribue à la posture de sécurité globale d'une organisation, par ses choix de mots de passe, sa vigilance face aux emails suspects et le respect des politiques internes.

2. Authentification et gestion des accès

L'authentification vérifie qu'un utilisateur est bien celui qu'il prétend être, tandis que l'autorisation détermine ce qu'il a le droit de faire une fois identifié.

Facteurs d'authentification

Facteur	Exemple
Ce que l'on sait	Mot de passe, code PIN, question secrète.
Ce que l'on possède	Téléphone, clé de sécurité physique, carte à puce.
Ce que l'on est	Empreinte digitale, reconnaissance faciale (biométrie).

L'authentification multifacteur (MFA) combine au moins deux de ces facteurs : elle réduit fortement le risque lié à un mot de passe compromis.

Bonnes pratiques de mots de passe

- Utiliser un mot de passe long et unique pour chaque service (12 caractères ou plus).
- Préférer une phrase de passe facile à retenir mais difficile à deviner.
- Utiliser un gestionnaire de mots de passe plutôt que de les réutiliser ou les noter.
- Activer la MFA partout où elle est disponible, en particulier sur les comptes sensibles.

Principe du moindre privilège

Chaque utilisateur ou service ne doit disposer que des droits strictement nécessaires à l'exécution de ses tâches. Ce principe limite l'impact d'un compte compromis et facilite la traçabilité des actions sensibles.

3. Cryptographie et protection des données

La cryptographie protège la confidentialité et l'intégrité des données, au repos comme en transit, en les rendant illisibles sans la clé appropriée.

Chiffrement symétrique et asymétrique

Type	Fonctionnement
Chiffrement symétrique	Une même clé secrète sert à chiffrer et déchiffrer (ex : AES).
Chiffrement asymétrique	Une paire clé publique / clé privée ; ce que l'une chiffre, l'autre seule le déchiffre (ex : RSA).
Fonction de hachage	Transforme une donnée en empreinte unique, non réversible (ex : SHA-256).

Hachage et stockage des mots de passe

Un mot de passe ne doit jamais être stocké en clair. On stocke à la place son empreinte, obtenue via une fonction de hachage lente et salée, spécialement conçue pour cet usage (comme bcrypt ou Argon2), afin de résister aux attaques par force brute.

HTTPS et certificats

Le protocole HTTPS combine HTTP et TLS pour chiffrer les échanges entre un navigateur et un serveur. Un certificat numérique, délivré par une autorité de certification, permet de vérifier l'identité du site visité et d'établir une connexion chiffrée de confiance.

Le petit cadenas affiché par le navigateur confirme que la connexion est chiffrée, mais ne garantit pas que le site lui-même est légitime : il faut aussi vérifier l'adresse (URL).

4. Sécurité réseau

La sécurité réseau vise à contrôler les flux de données entre systèmes, à limiter les accès non désirés et à détecter les activités anormales.

Composants courants

Composant	Rôle
Pare-feu (firewall)	Filtre le trafic réseau selon des règles définies (ports, adresses, protocoles).
VPN	Crée un tunnel chiffré entre deux points sur un réseau public.
IDS / IPS	Détecte (IDS) ou bloque activement (IPS) les activités suspectes sur le réseau.
Segmentation réseau	Divise le réseau en zones isolées pour limiter la propagation d'une intrusion.

Réseaux Wi-Fi et postes de travail

- Utiliser WPA3 (ou WPA2 à défaut) plutôt que des protocoles Wi-Fi obsolètes.
- Séparer le réseau invité du réseau interne de l'organisation.
- Maintenir à jour le firmware des routeurs et équipements réseau.
- Éviter les réseaux Wi-Fi publics non chiffrés pour des opérations sensibles, ou utiliser un VPN.

Défense en profondeur

Aucune mesure de sécurité n'est infaillible à elle seule. La défense en profondeur consiste à superposer plusieurs couches de protection (réseau, système, application, utilisateur) afin qu'une défaillance isolée ne compromette pas l'ensemble du système.

5. Menaces courantes et ingénierie sociale

De nombreuses attaques ne visent pas directement la technique, mais exploitent la confiance ou l'inattention humaine. Connaître ces menaces est la première étape pour s'en protéger.

Panorama des menaces

Menace	Description
Hameçonnage (phishing)	Message frauduleux imitant une source fiable pour voler des informations.
Rançongiciel (ransomware)	Logiciel malveillant qui chiffre les données et exige une rançon.
Logiciel malveillant (malware)	Terme général pour tout logiciel conçu pour nuire (virus, cheval de Troie...).
Ingénierie sociale	Manipulation psychologique visant à obtenir des informations ou un accès.

Reconnaître un email de hameçonnage

- Expéditeur ou domaine légèrement différent de l'officiel.
- Sentiment d'urgence, menace ou promesse inhabituelle.
- Liens ou pièces jointes inattendus, demande d'identifiants ou de paiement.
- Fautes d'orthographe ou mise en forme approximative.

En cas de doute sur un message, ne jamais cliquer sur les liens : contacter l'expéditeur par un autre canal connu, ou signaler le message à l'équipe informatique.

6. Sécuriser les applications web

Les applications web constituent une cible fréquente car elles sont exposées publiquement. Le projet OWASP recense chaque année les catégories de risques les plus critiques pour guider les équipes de développement.

Grandes catégories de risques (OWASP)

Catégorie	Principe de protection
Contrôle d'accès défaillant	Vérifier systématiquement les droits côté serveur, pas seulement côté interface.
Faibles d'injection	Utiliser des requêtes préparées et valider/échapper toutes les entrées utilisateur.
Configuration non sécurisée	Désactiver les fonctionnalités inutiles et appliquer les correctifs de sécurité.
Composants vulnérables	Maintenir à jour les bibliothèques et frameworks utilisés.
Journalisation insuffisante	Enregistrer et surveiller les événements de sécurité pour détecter les incidents.

Principes de développement sécurisé

- Ne jamais faire confiance aux données envoyées par le client ; toujours les valider côté serveur.
- Appliquer le principe du moindre privilège aux comptes de service et bases de données.
- Chiffrer les données sensibles au repos et en transit.
- Intégrer des tests de sécurité tout au long du cycle de développement (DevSecOps).

7. Gestion des incidents et bonnes pratiques

Même avec de bonnes défenses, aucun système n'est invulnérable. Se préparer à réagir efficacement à un incident est aussi important que de chercher à le prévenir.

Étapes clés de la réponse à incident

Étape	Objectif
Détection	Identifier rapidement une activité anormale ou une compromission.
Confinement	Isoler les systèmes touchés pour limiter la propagation.
Éradication	Supprimer la cause de l'incident (accès, logiciel malveillant, etc.).
Rétablissement	Restaurer les systèmes à partir de sauvegardes saines et vérifiées.
Retour d'expérience	Analyser l'incident pour renforcer les défenses futures.

Sauvegardes et mises à jour

La règle du **3-2-1** reste une référence : conserver au moins 3 copies des données, sur 2 supports différents, dont 1 hors site (ou hors ligne, à l'abri d'un rançongiciel). Les mises à jour de sécurité doivent être appliquées rapidement, car de nombreuses attaques exploitent des failles déjà corrigées par l'éditeur.

Bonnes pratiques générales

- Activer la MFA et utiliser des mots de passe uniques et robustes.
- Maintenir systèmes, navigateurs et logiciels à jour.
- Sauvegarder régulièrement les données importantes, hors ligne si possible.
- Se méfier des messages et liens inattendus, même provenant de contacts connus.
- Former et sensibiliser régulièrement les utilisateurs aux risques actuels.

Fin du guide — bonne pratique de la sécurité informatique au quotidien !